

Mapeo Detallado de Preguntas a Requisitos Normativos

Tabla de Trazabilidad: Encuesta COSO-Ciber → Marcos Regulatorios y Estándares

Kit COSO-Ciber v2025.1

"La trazabilidad normativa convierte un instrumento de diagnóstico en un activo de cumplimiento. Cada pregunta que responde el encuestado deja un rastro verificable hacia el requisito regulatorio que justifica su existencia."

Clave de Marcos Normativos Utilizados

Código	Marco	Referencia Completa
COSO-ERM	COSO Enterprise Risk Management	COSO ERM 2017 — 20 Principios
COSO-IC	COSO Internal Control	COSO IC 2013 — 17 Principios
COSO-CGF	COSO Corporate Governance Framework	COSO CGF 2026
NIS2	Directiva NIS2	Directiva UE 2022/2555
DORA	Digital Operational Resilience Act	Reglamento UE 2022/2554
ENS	Esquema Nacional de Seguridad	Real Decreto 311/2022
ISO27001	ISO/IEC 27001:2022	Cláusulas y Anexo A
NIST-CSF	NIST Cybersecurity Framework 2.0	NIST CSF 2.0 (2024)
NIST-ERM	NIST IR 8286r1	NIST IR 8286r1 (2025)
FAIR	Factor Analysis of Information Risk	ANSI/OpenFAIR 2023
GDPR	Reglamento General de Protección de Datos	Reglamento UE 2016/679
CMMC	Cybersecurity Maturity Model Certification	CMMC 2.0 (DoD, 2024)
CCNGUIA	Guías CCN-STIC	CCN-STIC-800 series

Tabla de Mapeo Completo

Preg unta	Títul o	COS O ERM (Prin cipio)	COS O IC	COS O CGF 2026	NIS2 (Artíc ulo)	DOR A (Artíc ulo)	ENS (Ane xo/A rt.)	ISO 2700 1:20 22	NIST CSF 2.0	NIST- ERM	FAIR	GDP R
P-0.5	Clasifi cación regul atoria	—	—	—	Art. 3	Art. 2	Art. 3	—	—	—	—	—
P-0.6	Pres upue sto ciber % TI	P-4 (Dem uestr a comp romi so)	CC1.1	P-8	Art. 21(2)	Art. 6	Dime nsión Org.	5.1, 6.3	GV.R M-05	IR- 8286 \$2.1	—	—
P-0.7	Tend encia pres upue stari a	P-4, P-16	CC1.1	P-8	Art. 21(2)	Art. 6	—	5.1, 9.3	GV.R M-05	IR- 8286 \$2.1	—	—
P-1.1 ⚡	Sup ervi sión del ciber riesg o por el Cons ejo	P-2 (Sup ervi sión del conse jo)	CC1.2	P-8 (nucl ear)	Art. 20(1)	Art. 5(1)	—	5.1	GV.O C-05	IR- 8286 \$2.1	—	Art. 24
P-1.2 ⚡	Com peten cia ciber del Cons ejo	P-2, P-4	CC1.2	P-8	Art. 20(2)	Art. 5(2)	—	5.1, 7.2	GV.O C-03	IR- 8286 \$2.1	—	—

P-1.3	Comité especializado de ciberseguridad	P-2, P-3	CC1.2	P-8	Art. 20(1)	Art. 5(1)	—	5.1	GV.O C-04	—	—	—
P-1.4 ⚡	Línea de reporte del CISO	P-2, P-3	CC1.2, CC1.3	P-8	Art. 20(2)	Art. 5(2), Art. 16	Org. Seguridad	5.3	GV.O C-02	IR-8286 \$2.1	—	Art. 37
P-1.5	Declaración de apetito de ciberriesgo	P-6, P-9	CC3.1	—	Art. 21(1)	Art. 6(8)	Marc o Gov.	5.1, 6.1.1	GV.R M-04	IR-8286 \$2.2	OB-1	—
P-1.6 ⚡	Cultura organizacional ciber	P-4, P-5	CC1.4, CC1.5	P-8	Art. 21(2g)	Art. 13	Dimensión Org.	7.3	GV.A T-02	—	—	Art. 25 (PbD)
P-1.7	Formación y concienciación	P-4 (Personas)	CC1.3	—	Art. 21(2g)	Art. 13(6)	Marc o Form.	7.2, 7.3	PR.A T-01	—	—	Art. 32(1b)
P-1.8	Gestión del talento ciber	P-4	CC1.3	—	Art. 21(2g)	—	—	7.2	GV.O C-03	—	—	—
P-2.1 ⚡	Integración ciber en la estrategia	P-6, P-7 (Objetivos)	CC3.1	—	Art. 21(1)	Art. 6(1)	—	4.1, 6.1.1	GV.R M-01	IR-8286 \$2.2	—	—

P-2.2	Cuan- tifica- ción finan- ciera del ciber- riesg- o	P-8 (Eval- uación de riesg- os)	CC3.2	—	Art. 21(2a)	Art. 8(1)	—	6.1.2	GV.R M-06	IR- 8286 §3	FAIR Mod- elo	—
P-2.3 ⚡	Expr- esión del apeti- to de riesg- o	P-9 (Res- puest- a al riesg- o)	CC3.1	—	Art. 21(1)	Art. 6(8), Art. 17	—	5.1, 6.1.1	GV.R M-04	IR- 8286 §2.2	OB-1	—
P-2.4	Eval- uación ciber- en inicia- tivas estra- tégic- as	P-7, P-8	CC3.2	—	Art. 21(2b)	Art. 8(2)	—	6.1.2, 8.3	ID.R A-06	IR- 8286 §2.2	—	Art. 35 (PIA)
P-2.5	Inteli- genci- a de amen- azas	P-6 (Cont- exto exter- no)	—	—	Art. 21(2e)	Art. 11	—	A-5.7	ID.R A-02	—	—	—
P-2.6	Segu- ro de ciber- riesg- o	P-9 (Res- puest- a al riesg- o)	—	—	—	Art. 6(7)	—	6.1.3	GV.R M-07	IR- 8286 §3.3	—	—
P-3.1 ⚡	Regis- tro de riesg- os ciber	P-8, P-10	CC3.2 , CC4.1	—	Art. 21(2a)	Art. 8(3)	Anex- o II	6.1.2, 8.2	ID.R A-01	IR- 8286 §2.3	—	Art. 32

P-3.2 ⚡	Gestión de vulnerabilidades	P-10, P-11	CC4.1	—	Art. 21(2e)	Art. 9(2)	Dimensión Req.	A-8.8, A-8.19	ID.R A-01, PR.IP-12	—	—	Art. 32(1b)
P-3.3 ⚡	Time-to-Patch (TTP)	P-11, P-12	CC4.1	—	Art. 21(2e)	Art. 9(2), Art. 25	D.CC. 3	A-8.8	PR.IP-12	—	—	Art. 32(1b)
P-3.4 ⚡	Time-to-Exploit (TtE) como KRI	P-11, P-15	CC4.1	—	Art. 21(2e)	Art. 9(2)	—	A-8.8	ID.R A-02	IR-8286 \$2.3	—	—
P-3.5 ⚡	MTT Dy MTT R	P-11, P-12, P-15	CC4.1, CC7.4	—	Art. 21(2b), Art. 23	Art. 10, Art. 18	D.CC. 5	A-5.26, A-5.27	DE.C M, RS.R P	IR-8286 \$2.3	—	Art. 33(1)
P-3.6 ⚡	Gestión IAM /PA My cobertura MFA	P-10, P-11	CC6.1, CC6.2, CC6.3	—	Art. 21(2i)	Art. 9(3)	D.AC. 1, D.AC. 2	A-5.15, A-8.2, A-8.5	PR.A A-01 a 06	—	—	Art. 25, 32
P-3.7	Arquitectura Zero Trust	P-11	CC6.6, CC6.7	—	Art. 21(2h)	Art. 9(3)	D.SE. 3	A-8.2, A-8.20	PR.A A-05, PR.P S-04	—	—	Art. 32
P-3.8 ⚡	Riesgo de terceros y supply chain	P-8, P-11	CC9.1, CC9.2	—	Art. 21(2d), Art. 22	Art. 28, Art. 30	Marc o Prov.	A-5.19 a 5.22, A-8.30	ID.SC -01 a 05	IR-8286 \$2.3	—	Art. 28

P-3.9 ⚡	Resiliencia y continuidad de negocio	P-11, P-12	CC9.1, CC7.5	—	Art. 21(2c)	Art. 11, Art. 12	Dimensión Cont.	A-5.29, A-5.30, A-8.13	PR.IP-09, RC.RP	IR-8286 \$2.3	—	Art. 32(1c)
P-3.10	Seguridad OT/IOT/ICS	P-10, P-11	CC6.6	—	Art. 21(2h), Anexo I/II	Art. 9(4)	—	A-8.9, A-8.22	PR.PS, ID.AM	—	—	—
P-3.11 ⚡	Vista de cartera del ciberriesgo	P-9, P-16	CC3.3	P-8	Art. 21(1)	Art. 8(1)	—	6.1.2, 9.1	GV.RM-02	IR-8286 \$4	FAIR Portfolio	—
P-4.1 ⚡	IA adversarial como riesgo emergente	P-6 (Contexto)	CC3.2	—	Art. 21(2a, 2e)	Art. 8(2)	—	A-5.7, A-8.16	ID.RA-02	—	—	—
P-4.2 ⚡	Quantum readiness / PQC	P-6, P-15	CC3.2	—	Art. 21(2h)	Art. 9(3b)	—	A-8.24	PR.DS-10	—	—	Art. 32(1a)
P-4.3	Seguridad de IA propia	P-6, P-11	CC4.1	—	Art. 21(2h)	—	—	A-5.7, A-8.25	ID.RA, PR.PS	—	—	EU AI Act
P-4.4	Seguridad cloud / multcloud	P-10, P-11	CC6.6, CC6.7	—	Art. 21(2f, 2h)	Art. 9(3), Art. 28	D.SE.3, D.SE.4	A-5.23, A-8.10, A-8.23	PR.AA, PR.DS	—	—	Art. 28, 46

P-5.1 ⚡	Cumplimiento NIS2	P-8, P-20	CC2.2 , CC4.1	—	Arts. 18–23 (todos)	—	—	4.2, 9.3	GV.P O-01	—	—	—
P-5.2	Proceso de notificación de incidentes	P-17, P-20	CC7.4 , CC7.5	—	Art. 23 (plazos 24h/72h)	Art. 19 (plazos 4h/24h)	Art. 40-41	A-5.26, A-6.8	RS.C O-02	—	—	Art. 33 (plazos 72h)
P-5.3	Certificaciones vigentes	P-20	CC2.2	—	Art. 24 (esquemas cert.)	Art. 24	RD 311/2022	ISO 27001 completo	—	—	—	—
P-5.4	Cumplimiento como driver de inversión	P-4, P-16	CC2.2	—	Art. 21(2)	Art. 6(1)	—	5.1	GV.R M-05	—	—	—
P-6.1 ⚡	Madurez general del programa ciber	P-11 (Actividades de control)	CC1–CC9	—	Art. 21(1)	Arts. 6–25	Todos	Todos	Todos	IR-8286 completo	—	Art. 32
P-6.2	Benchmarking externo	P-15, P-16	CC4.2	—	Art. 21(1)	Art. 6(8)	—	9.1, 9.3	ID.I M-01	—	—	—
P-6.3 ⚡	Frecuencia evaluaciones independientes	P-16, P-17	CC4.1 , CC4.2	—	Art. 21(2f)	Art. 26 (TLP T)	Auditorías ENS	9.2, 9.3	ID.I M-02	—	—	Art. 32

P-6.4	Plataforma GRC	P-17	CC4.1, CC5.3	—	Art. 21(2a)	Art. 8(3)	—	5.1, 9.1	GV.O C-01	IR-8286 \$4	—	—
P-6.5	Proceso post-incidente (lecciones)	P-16, P-17	CC7.5	—	Art. 23(6) (informe final)	Art. 19(4)	—	A-5.27, A-5.26	RC.I M-01, 02	—	—	Art. 33(5)
P-7.1 ⚡	Calidad del reporte al Consejo	P-19, P-20	CC2.2	P-8	Art. 20(2)	Art. 5(2)	—	5.1, 9.3	GV.O C-05	IR-8286 \$2.1	—	—
P-7.2	Indicadores en el reporte al Consejo	P-19, P-20	CC2.2	P-8	Art. 20(2), Art. 21	Art. 5(2), Art. 8	—	5.1, 9.1	GV.O C-05	IR-8286 \$2.1	—	—
P-7.3 ⚡	Protocolo de escalado a incidentes	P-18, P-19	CC7.4, CC2.2	—	Art. 20(2), Art. 23	Art. 19, Art. 5(2)	Art. 40	A-5.26	RS.C O-03	—	—	Art. 33
P-7.4	Comunicación externa ante incidentes	P-19, P-20	CC2.3	—	Art. 23(3), Art. 34	Art. 19(3)	—	A-5.26, A-6.8	RS.C O-01	—	—	Art. 34

P-8.1 ⚡	Medición del ROI de la inversión ciber	P-9, P-16	CC3.3	P-8	Art. 21(1)	Art. 8(1)	—	9.1	GV.R M-06	IR-8286 §3	ROSI Fórmula	—
P-8.2	Autoevaluación IGM	P-11, P-16, P-17	Todos	—	Art. 21(1)	Art. 6(1)	Todos	9.1	ID.I M-02	IR-8286 §4	—	—
P-8.3	Barreiras para la mejora	P-4, P-16	CC1.3	—	—	—	—	7.2, 9.3	GV.O C	—	—	—
P-9.1	Comparativa con la media del sector	P-15, P-16	CC4.2	—	—	—	—	9.1	ID.I M-01	—	—	—
P-9.2	Incidentes sufridos (tipología)	P-16, P-17	CC7.4 , CC7.5	—	Art. 23	Art. 19	Art. 40	A-5.27	RS.R P	—	—	Art. 33
P-9.3	Prioridades de inversión 2026	P-9, P-16	CC3.3	P-8	Art. 21	Arts. 6-25	—	6.1.3, 9.3	GV.R M	IR-8286 §3	—	—
P-10.1	Valoración marco COSO	—	—	—	—	—	—	—	—	IR-8286	—	—

P-10.2	Métrica transformadora	—	—	—	—	—	—	—	—	—	—	—
P-10.3	Mayor reto 2026	—	—	—	—	—	—	—	—	—	—	—
P-10.4	Indicadores a incorporar	—	—	—	—	—	—	—	—	—	—	—

Tabla de Densidad Normativa por Pregunta

Esta tabla resume el número de marcos normativos que cada pregunta activa, como indicador de su peso regulatorio y su relevancia para el cumplimiento multimarca.

Pregunta	Marcos Activos	Peso Regulatorio	IAT
P-1.1	8	★★★★★	⚡
P-3.5 (MTTD/MTTR)	9	★★★★★	⚡
P-3.6 (IAM/MFA)	9	★★★★★	⚡
P-3.8 (Supply Chain)	10	★★★★★	⚡
P-3.9 (Resiliencia/BCP)	10	★★★★★	⚡
P-5.2 (Notificación incidentes)	8	★★★★★	—
P-7.3 (Protocolo escalado)	8	★★★★★	⚡
P-2.2 (Cuantificación FAIR)	7	★★★★☆	—
P-3.3 (Time-to-Patch)	7	★★★★☆	⚡
P-4.4 (Seguridad cloud)	7	★★★★☆	—
P-4.2 (Quantum/PQC)	6	★★★☆☆	⚡
P-4.3 (Seguridad IA)	6	★★★☆☆	—
P-5.3 (Certificaciones)	5	★★★☆☆	—

Cobertura de Marcos por Bloque

Bloque	NIS2	DORA	ENS	ISO 27001	NIST CSF	COSO ERM	FAIR	GDPR
I — Gobernanza	✓	✓	✓	✓	✓	✓	—	✓
II — Estrategia	✓	✓	—	✓	✓	✓	✓	✓
III — Desempeño	✓	✓	✓	✓	✓	✓	—	✓
IV — Riesgos Emergentes	✓	✓	✓	✓	✓	✓	—	✓
V — Regulatorio	✓	✓	✓	✓	✓	✓	—	✓
VI — Revisión /Mejora	✓	✓	✓	✓	✓	✓	—	✓
VII — Reporte /Comunicación	✓	✓	✓	✓	✓	✓	—	✓
VIII — ROI/IGM	✓	✓	✓	✓	✓	✓	✓	—
IX — Perspectiva comparada	✓	✓	—	✓	✓	✓	—	—

Notas de Interpretación

1. COSO ERM Principios numerados según la estructura del documento COSO ERM 2017 (20 Principios agrupados en 5 Componentes).
2. COSO IC componentes referenciados por códigos CC del SOC 2 Trust Services Criteria (derivados directamente de COSO IC 2013).
3. NIS2 artículos según la numeración de la Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo.
4. DORA artículos según el Reglamento (UE) 2022/2554.
5. ENS referenciado según el Real Decreto 311/2022 y sus Guías CCN-STIC asociadas.
6. ISO 27001:2022 referenciado por cláusulas (5–10) y controles del Anexo A (A-5 a A-8).
7. NIST CSF 2.0 referenciado por función (GV, ID, PR, DE, RS, RC) y categoría.
8. FAIR referenciado según la ontología FAIR (Open FAIR Taxonomy, 2023).
9. EU AI Act aplica específicamente a P-4.3 (sistemas de IA de alto riesgo; Arts. 9–15 del Reglamento UE 2024/1689).

Mapeo Normativo — Kit COSO-Ciber v2025.1 / Abril 2026